

AUDITORÍA DE SEGURIDAD WEB

-Objetivo: <http://www.tokiohacking.com/>

- Introducción / Objeto de la auditoría

El objeto de esta auditoría es evaluar la seguridad de la infraestructura web de tokiohacking.com. Se busca identificar vectores de ataque, configuraciones inseguras y exposición de información

sensible mediante técnicas no intrusivas. El alcance incluye el análisis del servidor web principal y los servicios asociados de red.

- Se inicia la fase de reconocimiento activo mediante la herramienta **nslookup**. Esta permite verificar la resolución de nombres del dominio tokiohacking.com y su subdominio www, identificando las direcciones IP públicas (31.214.178.55 y 31.214.178.4). Esto confirma que el servicio web está alojado en la infraestructura de Dondominio .

```
(kali@kali)-[~]  
$ nslookup tokiohacking.com  
nslookup www.tokiohacking.com  
Server:      192.168.30.2  
Address:     192.168.30.2#53  
  
Non-authoritative answer:  
Name:   tokiohacking.com  
Address: 31.214.178.55  
  
Server:      192.168.30.2  
Address:     192.168.30.2#53  
  
Non-authoritative answer:  
www.tokiohacking.com canonical name = hostingsrv18.dondominio.com.  
Name:   hostingsrv18.dondominio.com  
Address: 31.214.178.4
```

- Para completar el perfil del objetivo, se ha utilizado Netcraft. Esta herramienta nos permite obtener un información de la infraestructura sin interactuar con el servidor. Como se observa en la captura siguiente, el sitio fue detectado por primera vez en octubre de 2023 y utiliza un servidor Apache. Esta información confirma que estamos ante una infraestructura estable y profesional (gestionada por Dondominio), lo que descarta el uso de servidores mal

configurados que suelen ser más vulnerables

[LEARN MORE](#)[REPORT FRAUD](#)

Share: [G](#) [X](#) [f](#) [in](#) [V](#)

Background

Site title	Inicio	Date first seen	October 2023
Site rank	196788	Primary language	Spanish
Description	Not Present		

Network

Site	http://www.tokiohacking.com	Domain	tokiohacking.com
Netblock Owner	Soluciones Corporativas IP, SL	Nameserver	ns1.dondominio.com
Hosting company	Soluciones Corporativas IP	Domain registrar	scip.es
Hosting country	ES	Nameserver organisation	whois.scip.es
IPv4 address	31.214.178.4 (VirusTotal)	Organisation	Redacted for privacy, Redacted for privacy, Redacted for privacy, Spain
IPv4 autonomous systems	AS57910	DNS admin	dnsadmin@dondominio.com
IPv6 address	Not Present	Top Level Domain	Commercial entities (.com)
IPv6 autonomous systems	Not Present	DNS Security Extensions	Enabled
Reverse DNS	hostingsrv18.dondominio.com		

- Problemas encontrados

Tras un análisis exhaustivo, se han detectado los siguientes puntos de riesgo:

- Con **Nmap** realizamos una radiografía del servidor para ver qué servicios están expuestos a internet.

Qué encontramos: Detectamos tres servicios clave: DNS (puerto 53), HTTP (puerto 80) y HTTPS (puerto 443).

El hallazgo crítico: El servicio DNS reveló su versión exacta: dnsmasq 2.90. En seguridad, esto se considera una fuga de información, ya que un atacante puede buscar fallos específicos para esa versión.

```
(kali㉿kali)-[~]
$ nmap -sC -sV -T4 31.214.178.4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-24 18:25 +0100
Nmap scan report for hostingsrv18.dondominio.com (31.214.178.4)
Host is up (0.00092s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain  dnsmasq 2.90
| dns-nsid:
|_  bind.version: dnsmasq-2.90
80/tcp    open  http    Apache httpd
|_ http-server-header: Apache
|_ http-title: 403 Forbidden
443/tcp   open  ssl/http Apache httpd
|_ ssl-cert: Subject: commonName=*.dondominio.com
| Subject Alternative Name: DNS:*.dondominio.com, DNS:dondominio.com
| Not valid before: 2026-01-22T00:00:00
|_ Not valid after: 2027-02-21T23:59:59
|_ ssl-date: TLS randomness does not represent time
|_ http-server-header: Apache
|_ http-title: 403 Forbidden
|_ tls-alpn:
|   h2
|_  http/1.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 108.73 seconds
```

-FFUF es nuestra herramienta de "fuerza bruta" para encontrar carpetas que el dueño de la web no quiere que veamos.

Qué encontramos: Al probar miles de nombres de archivos (como .env, .git, backup), el servidor respondió sistemáticamente con un código 403 Forbidden.

Conclusión: Esto nos dice dos cosas: primero, que el servidor tiene reglas de seguridad que bloquean el acceso a archivos sensibles; y segundo, que el sistema es capaz de reconocer esas rutas. Aunque no pudimos entrar, confirmamos que el servidor está "blindado" contra curiosos.

```
kali@kali: ~  
Session Acciones Editar Vista Ayuda  
kali@kali: ~ nmap-gordo kali@kali: ~  
(kali@kali)-[~]  
$ ffuf -u http://www.tokiohacking.com/FUZZ -w /usr/share/wordlists/dirb/common.txt  
  
v2.1.0-dev  
  
:: Method : GET  
:: URL : http://www.tokiohacking.com/FUZZ  
:: Wordlist : FUZZ: /usr/share/wordlists/dirb/common.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
  
_backup [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 66ms]  
_config [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 68ms]  
_subversion [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 75ms]  
_mysql_history [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 69ms]  
_cvsignore [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 69ms]  
_baks [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 69ms]  
_bashrc [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 80ms]  
_bash_history [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 82ms]  
_ajax [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 79ms]  
_listings [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 80ms]  
_admin [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 83ms]  
_tmpfileop [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 44ms]  
_test [Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 50ms]
```

Uso de protocolo inseguro (HTTP): La página web principal no fuerza el uso de cifrado, permitiendo conexiones por el puerto 80.

Exposición de versiones de software: El servidor revela versiones específicas de sus servicios, como dnsmasq 2.90, lo que facilita ataques dirigidos.

Estructura de subdominios expuesta: Se han localizado accesos externos a servicios de gestión de correo (Webmail) que amplían la superficie de ataque.

Procesamiento de archivos sensibles: El servidor responde con códigos 403 Forbidden al intentar acceder a archivos críticos como .env o .bak, confirmando que

dichas rutas son procesadas por el sistema.

-Sugerencias y consejos para solucionar los problemas

Implementación de HTTPS: Forzar la redirección del tráfico del puerto 80 al 443 para garantizar la privacidad. Si un atacante aprovechara el puerto 80 abierto (HTTP), podría realizar un ataque Man-in-the-Middle para capturar credenciales de usuarios que intenten acceder al correo

Ofuscación de Banners: Configurar los servicios para que no devuelvan el número de versión en las cabeceras de respuesta.

Limpieza de Directorios: Eliminar físicamente archivos residuales de configuración que, aunque bloqueados, no deberían residir en el servidor de producción.

-Cronograma de instalación/configuración de medidas

1: Configuración de certificados SSL y redirecciones de seguridad.

2: Ajuste de las políticas de visibilidad de servicios y borrado de archivos residuales.

3: Auditoría de robustez de contraseñas en el panel de Webmail.

-Sistemas de gestión y políticas de usuario

Se recomienda implementar una política de "Mínimo Privilegio", asegurando que solo el personal autorizado tenga visibilidad sobre los servicios de gestión interna y reforzando el acceso al correo con autenticación de doble factor (2FA)

-Anexo I: Ajuste de inventario

Dominio principal: tokiohacking.com.

Direcciones IP: 31.214.178.4 (Web) y 31.214.176.67 (MX).

Servicios: Apache (Web), dnsmasq (DNS) y Roundcube (Webmail).

Ubicación: Hosting gestionado en España/Alemania bajo el proveedor Dondominio.

Para el ajuste del inventario de activos, se realizó una enumeración estándar de los registros DNS. Mediante la herramienta **DNSRecon**, se identificaron los servidores de nombres (NS), el servidor de intercambio de correo (MX) y se obtuvo el banner del servicio DNS (dnsmasq-2.90), lo

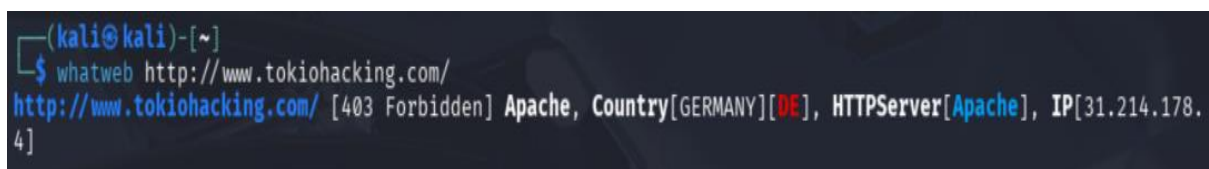
que permite mapear la infraestructura crítica de la organización.

```
(kali@kali)-[~]
$ dnsrecon -d tokiohacking.com -t std
2026-02-24T18:18:29.576322+0100 INFO Starting enumeration for domain: tokiohacking.com
2026-02-24T18:18:29.576609+0100 INFO std: Performing General Enumeration against: tokiohacking.com...
2026-02-24T18:18:29.679847+0100 ERROR No answer for DNSSEC query for tokiohacking.com
2026-02-24T18:18:29.753986+0100 INFO SOA ns1.dondominio.com 87.117.96.2
2026-02-24T18:18:29.839486+0100 INFO NS ns1.dondominio.com 87.117.96.2
2026-02-24T18:18:29.846923+0100 ERROR Recursion enabled on NS Server 87.117.96.2
2026-02-24T18:18:29.851617+0100 INFO Bind Version for 87.117.96.2 "dnsmasq-2.90"
2026-02-24T18:18:29.851758+0100 INFO NS ns2.dondominio.com 87.117.96.3
2026-02-24T18:18:29.858862+0100 ERROR Recursion enabled on NS Server 87.117.96.3
2026-02-24T18:18:29.861218+0100 INFO Bind Version for 87.117.96.3 "dnsmasq-2.90"
2026-02-24T18:18:29.930321+0100 INFO MX mx01.dondominio.com 31.214.176.67
2026-02-24T18:18:30.007326+0100 INFO A tokiohacking.com 31.214.178.55
2026-02-24T18:18:30.147059+0100 INFO TXT tokiohacking.com v=spf1 include:spf.dondominio.com
2026-02-24T18:18:30.241167+0100 INFO Enumerating SRV Records
2026-02-24T18:18:36.086787+0100 INFO SRV _autodiscover._tcp.tokiohacking.com autodiscover.panel247.com 37
.152.88.149 443
2026-02-24T18:18:36.990204+0100 INFO 1 Records Found
2026-02-24T18:18:36.990767+0100 INFO Completed enumeration for domain: tokiohacking.com
```

WhatWeb nos sirve para saber "de qué está hecha" la página sin mirar el código línea por línea.

Qué encontramos: Identificamos que la web corre sobre un servidor Apache y que el sistema operativo de fondo es Linux.

Lo más importante: Confirmamos que es una web estática (no usa WordPress, ni PHP, ni bases de datos visibles). Esto es una gran noticia para la seguridad de la empresa, ya que reduce drásticamente las posibilidades de ser hackeada mediante inyecciones SQL o fallos en plugins.



```
(kali@kali)-[~]  
$ whatweb http://www.tokiohacking.com/  
http://www.tokiohacking.com/ [403 Forbidden] Apache, Country[GERMANY][DE], HTTPServer[Apache], IP[31.214.178.4]
```

Sublist3r busca "puertas laterales" o subdominios que a veces se quedan olvidados o menos protegidos.

Qué encontramos: Encontramos dos subdominios: www.tokiohacking.com (la

web principal) y
webmail.tokiohacking.com.

El riesgo: El hallazgo del Webmail es el punto más sensible de toda la auditoría. Mientras que la web principal es estática y difícil de atacar, el Webmail es una plataforma interactiva de Roundcube donde se pueden intentar ataques de adivinación de contraseñas.

```
(kali@kali)-[~]  
$ sublist3r -d tokiohacking.com
```

Sublist3r

Coded By Ahmed Aboul-Ela - @aboul3la

```
[~] Enumerating subdomains now for tokiohacking.com  
[-] Searching now in Baidu..  
[-] Searching now in Yahoo..  
[-] Searching now in Google..  
[-] Searching now in Bing..  
[-] Searching now in Ask..  
[-] Searching now in Netcraft..  
[-] Searching now in DNSdumpster..  
[-] Searching now in Virustotal..  
[-] Searching now in ThreatCrowd..  
[-] Searching now in SSL Certificates..  
[-] Searching now in PassiveDNS..  
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page  
[!] Error: Virustotal probably now is blocking our requests  
[-] Total Unique Subdomains Found: 2  
www.tokiohacking.com  
webmail.tokiohacking.com
```

-Anexo II: Tabla de vulnerabilidades

CÓDIGO	VULNERABILIDAD	SOLUCIÓN
VULN-001	Exposición de versión DNS	Ocultar banner de dnsmasq
VULN-002	Puerto 80 Abierto	Redirección 301 a HTTPS
VULN-003	Fuga por Fuzzing (403)	Borrado de archivos .bak/.env

-Anexo III: Pasos para la configuración segura del acceso a la red

-Filtrado de IPs permitidas para el acceso al puerto 53 si no es un servidor público. Es recomendable que este puerto solo sea accesible por las IPs de los servidores de nombres autorizados, evitando que atacantes externos realicen consultas de versión o transferencias de zona que revelen la estructura interna de la red

-Instalación de un WAF (Web Application Firewall) para mitigar escaneos de directorios automatizados.

- Anexo IV: Presupuesto

Adecuación técnica inicial: 450,00 €.

Mantenimiento y revisión trimestral:
120,00 €/mes.

Soporte ante incidentes: Según tarifa por hora técnica.